

从新技术角度谈等级保护2.0

任 婷¹ 于 城²

¹ 公安部第三研究所 上海 200031

² 中国联通研究院 北京 100176

摘 要 信息安全等级保护制度是我国信息安全保护的基本制度，随着新技术的不断发展，等级保护也根据新形势进入了等保2.0时代。文章结合物联网、云计算、大数据、移动互联等新兴技术的等级保护需求，介绍等保2.0中针对新技术需要重点考虑的方面并对等级保护新技术部分进行总结概括和下一步演进建议。

关键词 等级保护；物联网；云计算；大数据；移动互联

引言

随着当前物联网、云计算、大数据、移动互联等新技术层出不穷，如何更好地保障国家安全，已经成了当前信息化发展中迫切需要解决的问题。当下除了物联网、云计算、大数据、移动互联网新技术，还有许多新兴技术日益成熟，比如人工智能、区块链、边缘计算等，这对等级保护提出了更高的要求。为了顺应当前的形势需要，信息安全等级保护制度也演变成了网络安全等级保护制度，简称等保2.0。本文首先介绍等级保护的发展背景，再针对等保2.0的内容划分，结合新技术的典型应用场景，重点谈谈针对新兴技术的等级保护应当重点考虑的方面。

1 背景

1999年9月，国家质量技术监督局颁布了第一个国家标准GB17859-1999《计算机信息系统安全防护等级划分指南》，它分五个等级对计算机信息系统安全进行保护：第一级即用户独立保护级，第二级即系统审计保护

级，第三级即安全标记保护级，第四级即结构化保护级，第五级即访问验证保护级；2003年8月，中共中央办公厅和国务院办公厅通过转发《国家信息化领导小组关于加强信息安全保障工作的意见》（中办发[2003] 27号），建立信息安全等级保护的指导思想，要求“实施信息安全等级保护”^[1]；2004年9月，公安部、国家密码管理局、国家保密局和国务院信息化工作办公室发布了《关于信息系统等级保护工作的实施意见》（公通字[2004]66号），将等级保护提升为国家信息安全保障的一项基本制度^[2]；2007年6月，公安部、国家密码管理局、国家保密局和国务院信息化工作办公室联合发布了《信息安全等级保护管理办法》（公通字[2007]43号），对信息安全级保护系统的基本内容、过程和工作要求进行说明^[3]；2008年6月，全国信息安全标准化技术委员会发布了GB/T 22240-2008《信息安全技术信息系统安全等级保护定级指南》，规定了信息系统安全等级保护的定级方法^[4]；2018年6月27日，公安部发布了《网络安全等级保护条例(征求意见稿)》，提出了全网等级保护的内容，从之前的重点是IDC机房等转变为

全网络、全终端、全业务的全面等级保护。

2 新技术典型应用场景及其安全需求

2.1 物联网应用场景

如图1所示，物联网系统从技术架构上来说通常是由感知层、网络层、应用层构成。其中感知层包括传感器节点和传感网网关节点，或者由RFID标签和RFID读写器构成的RFID系统，也包括这些感知设备及传感网网关、RFID标签与阅读器之间的短距离通信(通常为无线)部分；网络传输层包括将这些感知数据远距离传输到处理中心的网络，包括电信网、移动通信网等，以及几种不同网络的融合；处理应用层包括对感知数据进行存储与智能处理的平台，并对业务应用终端提供服务。对大型物联网来说，处理应用层一般是云计算平台和业务应用终端设备。

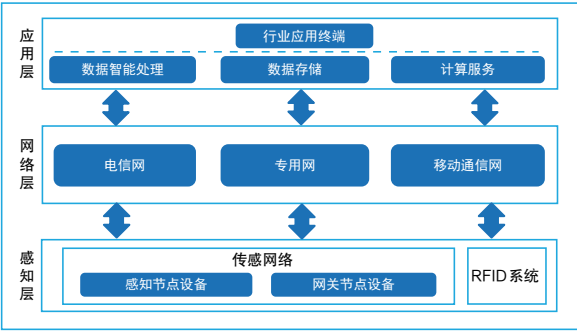


图1 物联网系统架构示例

感知层主要用于识别物体和采集信息，类似于人体的皮肤和五官，是物联网的核心，因此也是等级保护测评关注的重点。在测评中，重点关注感知层的感知节点设备和网关节点设备安全。

如图2所示，对于物理环境安全，等级保护重点应当在传感节点物理安全方面；对于网络通讯安全，等级保护重点在网络协议安全、网络通讯加密方面；对于区域边界安全，等级保护重点在感知层节点接入控制以及感知层节点入侵防范方面。对于计算环境安全方面，等级保护重点同样在感知节点和网关节点的计算安全方面，比如应用授权、身份授权、标识鉴别、过滤非法数据等。

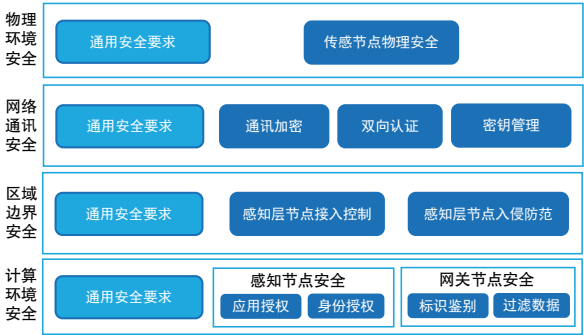


图2 物联网等级保护要点列表

2.2 云计算应用场景

如图3所示，云计算技术或者说云计算平台从服务角度通常分为IaaS(基础设施即服务)、PaaS(平台即服务)和SaaS(软件即服务)。一般来说，云服务商所提供的服务能力与云客户所需要自己实现的业务能力存在此消彼长的关系；也就是说云服务商提供服务越倾向于上层，云客户需要自己实现的能力要求就越轻量化。在不同的服务模式中，云服务商和云服务客户对计算资源拥有不同的控制范围，控制范围则决定了安全责任的边界。在基础设施即服务模式式下，云计算平台由基础设施、资源抽象控制层、虚拟化层组成；在平台即服务模式式下，云计算平台由基础设施、资源抽象控制层、虚拟化层、服务能力平台/软件集成平台/专用集成环境组成；在软件即服务模式式下，云计算平台包括基础设施、资源抽象控制层、虚拟化层、服务能力平台/软件集成平台/专用集成环境以及在线应用/软件/工具。

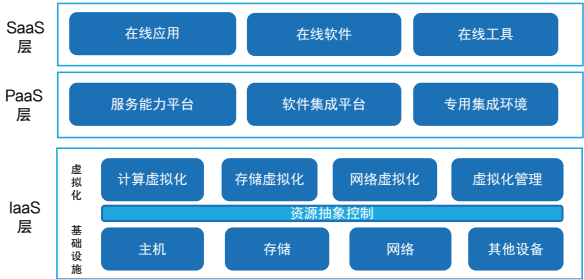


图3 云计算平台架构示例

如图4所示，等级保护云计算部分重点考虑主要集中在基础设施和虚拟层以及相关组件的安全。对于物理环境安全，等级保护重点应当在基础设施的物理安全以



图4 云计算等级保护要点列表

及计算/存储资源的跨境问题；对于网络通讯安全，等级保护重点在网络隔离、入侵防范、安全审计等方面；对于区域边界安全，等级保护重点在边界访问控制、边界入侵检测以及边界安全检测方面。对于计算环境安全方面，等级保护重点在接入层安全、虚拟化层安全、数据安全及与数据相关安全等方面，比如身份鉴别、访问控制、入侵防范、虚拟机镜像保护、数据完整性、数据保密性、数据备份恢复以及剩余信息保护等。

2.3 大数据应用场景

大数据集合的特征是体量大、种类多、聚合快、价值高，受到破坏、泄露或篡改会对国家安全、社会秩序或公共利益造成影响，大数据安全保护的原则以数据为核心，关注数据全生命周期包括数据采集、数据存储、数据应用、数据交换和数据销毁等环节的安全。如图5所示，大数据技术或者说是大数据系统通常由大数据平台、大数据应用构成。大数据平台为其支撑的大数据应用提供资源和服务的支撑集成环境，包括基础设施层、

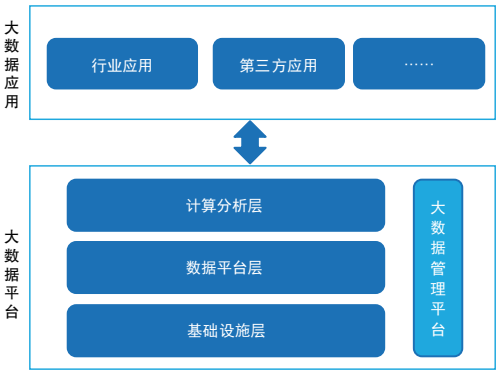


图5 大数据系统架构示例

数据平台层和计算分析层部分或者全部的功能；大数据应用完成数据采集、处理、存储、分析和展示功能，运用综合知识为数据创造价值。

如图6所示，等级保护大数据部分重点考虑基础设施、数据安全以及数据相关功能/组件的安全。对于物理环境安全，等级保护重点应当在基础设施的物理安全以及数据的跨境问题；对于网络通讯安全，等级保护重点应当考虑流量控制以及流量数据分离问题；对于计算环境安全，等级保护重点集中在身份鉴别、应用鉴别、业务连续性、对外服务安全以及数据相关安全方面。

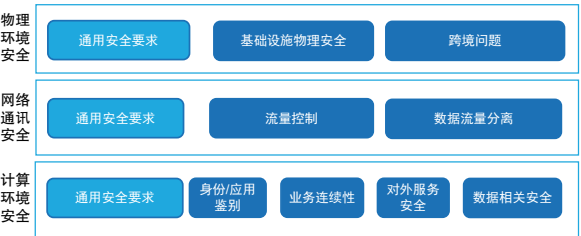


图6 大数据等级保护要点列表

2.4 移动互联应用场景

移动互联重点针对的是移动终端通过无线通道接入的应用场景。移动互联的典型结构是由移动终端、移动应用和无线网络三部分组成。移动终端通过无线通道连接无线接入设备，无线接入网关通过访问控制策略限制移动终端的访问行为，后台的移动终端管理系统负责对移动终端的管理，包括向客户端软件发送移动设备管理、移动应用管理和移动内容管理策略等。等级保护对移动终端部分的设计考虑是为了填补之前所欠缺的移动无线接入、无线移动互联部分，面向对象为移动终端、移动应用和无线网络的安全要求。

如图7所示，等级保护移动互联部分重点考虑在移动终端、无线接入网关以及相关的安全。对于物理环境安全，等级保护重点应当在移动终端和无线接入网关的物理安全问题；对于区域边界安全，等级保护重点应当在边界防护、访问控制以及入侵检测方面；对于计算环境安全，等级保护重点应当在移动终端管控和移动应用管控方面。

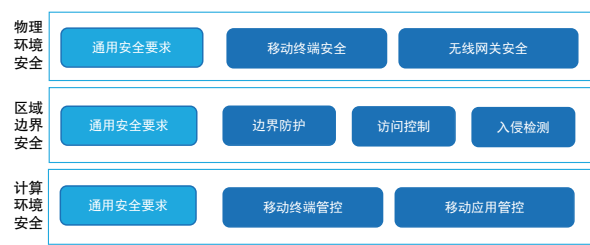


图7 移动互联网等级保护要点列表

3 新技术方面总结与下一步演进建议

3.1 新等保在新技术方面改进显著

新等保和旧等保相比最明显的地方就是结构调整，将之前的物理安全扩充成物理环境安全，将之前的网络安全扩充成网络通讯安全，将之前的主机安全、应用安全、数据安全及备份恢复合并并扩充成计算环境安全，增加了等级保护的范围。尤其重点考虑了可信计算的战略与相应措施，将区域边界安全单独划分出来，凸显了可信边界以及边界访问控制的重要性。并且新等保顺应当前新技术不断发展的态势，针对物联网、云计算、大数据等比较新的技术提出了对应的扩展要求。

物联网部分重点提出感知层安全保护要求：增加了感知节点的各方面安全要求，比如感知节点物理防护、感知节点设备安全、感知网关节点安全等；云计算部分重点提出虚拟化层安全保护要求：比如虚拟资源对应物理位置安全要求、镜像和快照保护、各类虚拟资源方面保护要求；移动互联网部分重点提出终端应用安全保护要求：增加了移动终端管控、移动应用管控以及移动应用开发等方面；数据安全以及大数据部分更加完善和强化数据生命周期中容易遗漏以及数据处置关键过程中的保护点：一方面侧重保护用户数据隐私，比如剩余信息保护、个人信息保护，另一方面从国家安全层面考虑，比如跨境问题、物理实际资源位置问题等。

3.2 实际等保评估需要改进

虽然新等保的扩展部分对物联网、云计算、大数据、移动互联网等方面提出了针对性的等级保护规定，但

是围绕新等保的实际实施和测评仍然有一定问题，有的是实施难度大，有的是测评范围不足。比如物联网部分，感知层作为物联网的最基础层次，具有分布范围广、节点数量庞大、节点类型多样化、协议混乱、传感节点设备更换升级困难等特性；如果针对某个物联网系统进行测评，感知层的普遍性测试评估对时间、人力要求极高，对专业技术、综合能力的要求也非常苛刻。再比如移动互联网部分，终端设备种类丰富，尤其是移动APP越来越普遍应用于各种系统的用户交互、数据展示、系统控制等场景；但是移动APP暴露出来的安全问题层出不穷，比如木马病毒、二次打包、篡改、钓鱼、信息劫持等；新等保虽然对移动应用管控做出了若干规定，但是保护范围还有待进一步加强。

3.3 等级保护在新技术方面演进建议

等级保护的宗旨一方面是保护国家网络安全，同时也保护个人信息安全、企业信息安全。虽然新等保提出了扩展要求来应对新技术带来的安全挑战，但是对于更多的新兴技术的保护涵盖范围仍显不足，如表1所示。

表1 新兴新技术示例保护点列表

新兴新技术领域	示例保护点	建议等保技术要求分类
人工智能	AI算法安全(防逆向分析) 训练集鉴别	计算环境安全 计算环境安全
5G/SDN	切片安全控制 自动化运维安全	网络通讯安全 网络通讯安全、物理环境安全
区块链	用户密钥保护机制	区域边界安全
边缘计算	边缘数据防篡改、防泄露	计算环境安全
容器化	容器镜像鉴别 容器应用安全	计算环境安全 计算环境安全

现在以人工智能、5G/SDN、区块链、边缘计算、容器化等已经基本成熟的新兴技术为例，阐述等级保护以后应当考虑的扩展要求或者说特殊保护要求。

人工智能方面，AI模型建立初期选择合法的训练集才能有效建立模型，尤其是无监督学习模型的影响更大，因为出现偏差或者错误不容易识别；AI平台必须进行训练集鉴别以保证合法的、没被篡改的训练集。AI模

型往往具备自学习、自修正的特点，所以AI算法安全特别重要；因为如果黑客获取到具体的AI算法或者通过逆向分析就可以根据算法弱点构造出特定的伪造数据，AI模型自修正很可能被误导，出现熊猫当苍蝇的情况。

5G的核心技术主要是SDN和虚拟网络切片。网络传输可以根据业务进行网络切片。切片安全控制就显得非常重要，一方面保证业务逻辑隔离、网络彼此不受影响，另一方面防范网络流量攻击。SDN软件定义网络对网络设备的要求比传统设备提高很多，网络设备的系统升级维护、业务调控往往需要自动化、智能化处理，这里会存在明显的安全风险，需要考虑自动化运维安全。

区块链目前广泛应用于金融、物流、安全等方面。区块链系统具有防篡改、去中心化、公开透明化、数据安全等特点，但是如果用户自己误操作删除认证私钥或者被黑客篡改密钥，意味着账户数据完全丢失，假如是比特币账户那么意味着其中的比特币永远丢失，所以应当建立并强化用户密钥保护机制。

边缘计算是将边缘端数据处理通过本地设备实现而无需交由云端，处理过程将在本地边缘计算层完成，为用户提供更快的响应，将需求在边缘端解决。这样边缘设备的数据安全会带来许多影响，一方面如果边缘数据被非法篡改会直接影响云端的业务判断；另一方面边缘设备计算处理后的结果数据泄露会比传感网络数据泄露危害风险更高。

容器技术具有低成本、可移植、灵活性、自动化、快速部署等优点，广泛应用于服务维护、应用部署等场景。但是容器安全同样应当注意，尤其避免使用来历不明的容器镜像，要检查镜像的合法性。这就要求系统/平台具备容器镜像鉴别保护能力；同时计算环境方面，

不当只关注容器服务的安全检测，同时需要注意容器中应用的安全检测，比如容器中应用软件版本升级、漏洞补丁维护等，同样非常关键。

因此，我们应当共同推进等级保护的进一步改进和发展，尤其是新兴技术方面的保护，真正达到全网络设备全终端的全面保护。

4 结束语

等级保护作为国家网络安全保护的基本制度，对国家的重要基础设施进行防护，从而有效确保国家网络安全。本文对物联网、云计算、大数据、移动互联网等几种新技术场景做了简单介绍，并针对性地从等级保护的角度做了简要分析。但是，新技术层出不穷，如何在日益成熟的新兴技术(人工智能、区块链、边缘计算等等)环境下实行等级保护，也是我们下一步需要深入研究的内容。

参考文献

- [1] 公安部第三研究所.国家信息化领导小组关于加强信息安全保障工作的意见(中版发[2003] 27号).2003[R]
- [2] 公安部,国家保密局,国家密码管理局,等.关于信息安全等级保护工作的实施意见(公通字[2004]66号)[EB/OL]. [2018-11-12].<http://www.itbuy365.com/?article-480.html>
- [3] 公安部,国家保密局,国家密码管理委员会办公室,等.信息安全等级保护管理办法(公通字[2007]43号)[EB/OL][2018-11-12]. <http://www.mps.gov.cn/n2254314/n2254409/n2254431/n2254438/c3697388/content.html>
- [4] 信息安全等级保护评估中心.GB/T22240-2008信息安全技术信息系统安全等级保护定级指南[M].北京:中国标准出版社,2008

作者简介

**任 婷**

硕士，研究实习员，研究方向为网络安全等级保护、安全评估。

**于 城**

硕士，工程师，研究方向为电信反欺诈、人工智能。

Analysis of Classified Protection 2.0 From the Perspective of New Technologies

Ren Ting¹
Yu Cheng²

1 The Third Research Institute of Ministry of Public Security, Shanghai 200031, China

2 China Unicom Research Institute, Beijing 100176, China

Abstract The information classified security protection system is the basic system of information security protection in China. With the continuous development of new technologies, the information classified security protection has also entered the era of protection 2.0 according to the new situation. This paper combines the classified protection needs of emerging technologies such as Internet of Things, cloud computing, big data, mobile internet and so on, and introduces the aspects that need to be considered for new technologies.

Keywords Information Classified Security Protection; Internet of Things; Cloud computing; Big Data; Mobile Internet

(上接11页)

Exploration and Practice of Telecommunication Operators on Internet-based Services

Kou Jinfeng^{1,2}
Zhang YunYong³
Tao Ye³
Liu Di²
Yan Shuo^{1,2}

1 Beijing University of Posts and Telecommunications, Beijing 100876, China

2 Network Technology Research Institution of China Unicom, Beijing 100033, China

3 China Unicom Research Institute, Beijing 100176, China

Abstract Information security risks caused by internet-based services are getting more serious recently, the Ministry of Industry and Information Technology has declared that the internet-based services must be assessed before putting into operation. In this paper, the severe situation in front of telecommunication operators is firstly analyzed, following with the general introduction and the implementing process of information security assessment, and suggested strategies are lastly proposed for telecommunication operators based on their work practice.

Keywords Information Security; Risk Assessment; Internet-based Service; Telecommunication Operators
